

Security with Tyk: Access Rights

In Tyk, Access rights control what APIs a client can use.

What are Access Rights in Tyk?

Tyk is an enterprise-grade API Gateway that controls authentication, authorization, and traffic governance.

It enforces these rules through:

- Access Rights (per-client permissions)
- Policies (centralized templates for rate limits, quotas, and scopes)

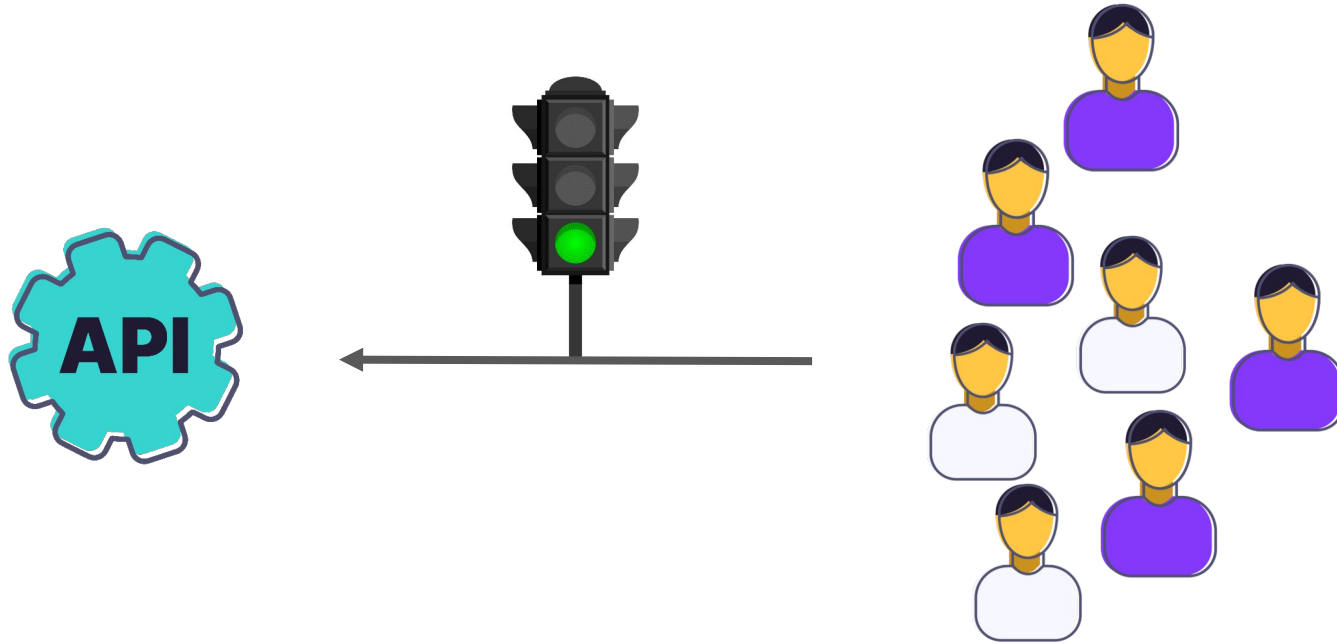
What an API Client Is Allowed to Access

Every API client (like a user, application, or service) is associated with an API Key or token. That key defines the client's Access Rights — a list of APIs and API versions it is allowed to call.

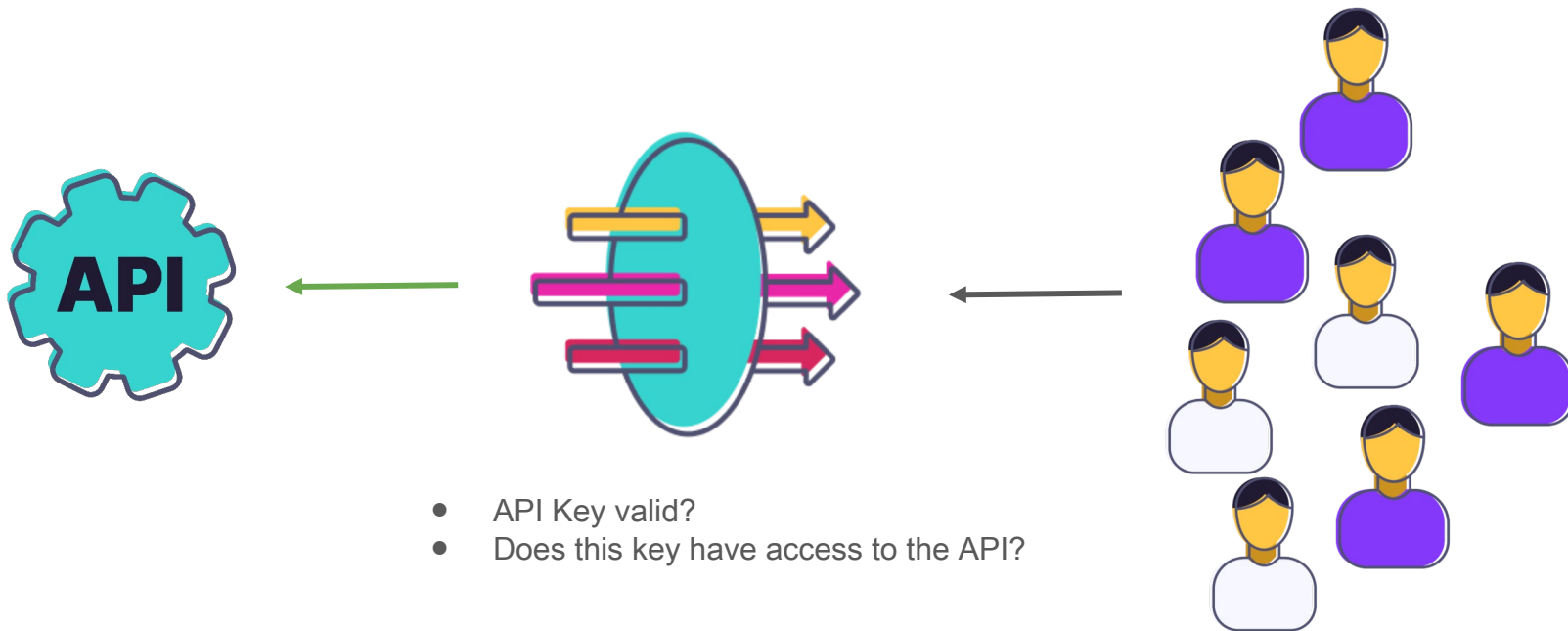
- You can explicitly allow specific APIs or versions.
- You do not need to define what is denied — if an API isn't listed, access is automatically blocked.

If the client tries to access an unauthorized API, the Tyk Gateway will reject the request with a 403 Forbidden error.

Without Access rights



Access Rights with Tyk



Define Access Rights

Access rights are configured in both API Key and Policy objects

Defined by the `access_rights` property:

- Contains a list of APIs which are allowed to be accessed
- Each API entry contains a list of versions which are allowed to be accessed

```
"access_rights": {  
  "e1d21f942ec746ed416ab97fe1bf07e8": {  
    "api_name": "Closed",  
    "api_id": "e1d21f942ec746ed416ab97fe1bf07e8",  
    "versions": ["Default"],  
    "allowed_urls": null  
  }  
},
```

Note: When new versions of an API are created, they are not automatically added to access rights

Access Rights: Path Based Permissions

Path-based permissions provide additional granular control of API access, based on HTTP methods and paths:

- Defined as the HTTP methods allowed for a path e.g. `GET /hello`
- Paths and methods act as an allow list

APIs must be selected in Access Rights to enable path-based permissions to be defined for them

Access Rights: Path-Based Permissions Enforcement

Enforcement is based on the permissions granted to the API client:

- If the requested API, HTTP method and path combination is not found in the path-based permissions then the request is blocked
- Example:
 - `/profile` allows GET requests, any POST requests for `/profile` are blocked

API clients which fail the path-based permissions check will be blocked:

- HTTP status code: 403 Forbidden

Policies: Reusable Access Templates

Rather than configuring access rights for every single API Key, Tyk lets you define Policies that group:

- Which APIs (and versions) can be accessed
- Quotas or usage limits
- Rate limiting rules
- Expiry rules or custom metadata

You assign policies to API keys, OAuth clients, or JWT tokens — making it easy to manage consistent access rules